

EOB Extractor — IAM Reference

Date: 2026-06-08
Principle: Least-privilege per Lambda function; permissions granted by CDK constructs.

1. Lambda IAM Roles Summary

Each Lambda function gets its own execution role. The table below lists all permissions explicitly granted.

eob-trigger

Action	Resource	Source
states:StartExecution	eob-extraction-pipeline state machine ARN	stateMachine.grantStartExecution(triggerFn)
dynamodb:GetItem, dynamodb:Query, dynamodb:Scan, dynamodb:BatchGetItem	eob-extractions table + all indexes	extractionsTable.grantReadData(triggerFn)
kms:Decrypt, kms:DescribeKey	alias/eob-extractor/phi	phiKey.grantDecrypt(triggerFn)
sqs:ReceiveMessage, sqs:DeleteMessage, sqs:GetQueueAttributes	eob-extractor-ingest queue	SQS event source mapping (auto-granted by CDK)
kms:Decrypt, kms:GenerateDataKey	alias/eob-extractor/phi	SQS KMS decrypt for ingest queue

Environment variables: - STATE_MACHINE_ARN — eob-extraction-pipeline ARN - TABLE_NAME — eob-extractions

eob-validate-pdf

Action	Resource	Source
s3:GetObject	bucket-specialops/clickup/*	eobBucket.grantRead(validatePdfFn, 'clickup/*')
s3:PutObject	bucket-specialops/quarantine/*	eobBucket.grantPut(validatePdfFn, 'quarantine/*')
kms:Decrypt, kms:DescribeKey	alias/eob-extractor/phi	phiKey.grantDecrypt(validatePdfFn)

Environment variables: - BUCKET_NAME — bucket-specialops[-sandbox]

eob-classify-eob

Action	Resource	Source
s3:GetObject	bucket-specialops/clickup/*	eobBucket.grantRead(classifyEobFn, 'clickup/*')

Action	Resource	Source
kms:Decrypt , kms:DescribeKey	alias/eob-extractor/phi	phiKey.grantDecrypt(classifyEobFn)
bedrock:InvokeModel	arn:aws:bedrock:us-east-1::foundation-model/anthropic.claude-haiku*	Inline policy
bedrock:InvokeModel	arn:aws:bedrock:us-east-2::foundation-model/anthropic.claude-haiku*	Inline policy
bedrock:InvokeModel	arn:aws:bedrock:us-west-2::foundation-model/anthropic.claude-haiku*	Inline policy
bedrock:InvokeModel	arn:aws:bedrock:us-east-1::foundation-model/anthropic.claude-sonnet*	Inline policy
bedrock:InvokeModel	arn:aws:bedrock:us-east-2::foundation-model/anthropic.claude-sonnet*	Inline policy
bedrock:InvokeModel	arn:aws:bedrock:us-west-2::foundation-model/anthropic.claude-sonnet*	Inline policy
bedrock:InvokeModel	arn:aws:bedrock:{region}:{account}:inference-profile/us.anthropic.claude-haiku*	Inline policy
bedrock:InvokeModel	arn:aws:bedrock:{region}:{account}:inference-profile/us.anthropic.claude-sonnet*	Inline policy

Environment variables: - `BUCKET_NAME` — bucket-specialops[-sandbox]

Reserved concurrency: 10

eob-extract-eob

Action	Resource	Source
s3:GetObject	bucket-specialops/clickup/*	eobBucket.grantRead(extractEobFn, 'clickup/*')
kms:Decrypt , kms:DescribeKey	alias/eob-extractor/phi	phiKey.grantDecrypt(extractEobFn)
bedrock:InvokeModel	arn:aws:bedrock:{us-east-1,us-east-2,us-west-2}::foundation-model/anthropic.claude-sonnet*	Inline policy
bedrock:InvokeModel	arn:aws:bedrock:{us-east-1,us-east-2,us-west-2}::foundation-model/anthropic.claude-haiku*	Inline policy
bedrock:InvokeModel	arn:aws:bedrock:{region}:{account}:inference-profile/us.anthropic.claude-sonnet*	Inline policy
bedrock:InvokeModel		Inline policy

Action	Resource	Source
	arn:aws:bedrock:{region}:{account}:inference-profile/us.anthropic.claude-haiku*	

Environment variables: - `BUCKET_NAME` — bucket-specialops[-sandbox]

Reserved concurrency: 10

Timeout: 300s (longest in the pipeline due to Bedrock PDF processing)

eob-validate-data

No AWS service calls. Executes Zod validation and business rules in-memory only.

No additional IAM permissions granted beyond the base Lambda execution role.

eob-lookup-insurance

Action	Resource	Source
dynamodb:Query	arn:aws:dynamodb:{region}:{account}:table/Insurance-Arbitration-contacts	Inline policy
dynamodb:Query	arn:aws:dynamodb:{region}:{account}:table/Insurance-Arbitration-contacts/index/*	Inline policy
dynamodb:PutItem	arn:aws:dynamodb:{region}:{account}:table/Insurance-Arbitration-contacts	Inline policy
sns:Publish	eob-extractor-review-alerts topic ARN	reviewAlertTopic.grantPublish(lookupInsuranceFn)

Environment variables: - `CONTACTS_TABLE_NAME` — Insurance-Arbitration-contacts - `NOTIFY_TOPIC_ARN` — eob-extractor-review-alerts ARN

Note: This Lambda writes to `Insurance-Arbitration-contacts` (an external table). The `dynamodb:PutItem` is granted via inline policy using the table name from CDK context. The write uses a conditional expression to prevent overwriting existing records.

eob-store-result

Action	Resource	Source
dynamodb:PutItem, dynamodb:UpdateItem, dynamodb:BatchWriteItem	eob-extractions table + all indexes	extractionsTable.grantWriteData(storeResultFn)
kms:Encrypt, kms:Decrypt, kms:GenerateDataKey	alias/eob-extractor/phi	phiKey.grant(storeResultFn, ...)
sqs:SendMessage	eob-extractor-review queue	reviewQueue.grantSendMessages(storeResultFn)
sns:Publish	eob-extractor-ops-alerts topic	opsAlertTopic.grantPublish(storeResultFn)

Action	Resource	Source
sns:Publish	eob-extractor-review-alerts topic	reviewAlertTopic.grantPublish(storeResultFn)

Environment variables: - `TABLE_NAME` — eob-extractions - `REVIEW_QUEUE_URL` — eob-extractor-review queue URL

2. Step Functions Execution Role

The Step Functions state machine (`eob-extraction-pipeline`) requires permission to invoke all 6 pipeline Lambda functions. CDK grants these automatically via `LambdaInvoke` tasks.

Action	Resource
lambda:InvokeFunction	eob-validate-pdf
lambda:InvokeFunction	eob-classify-eob
lambda:InvokeFunction	eob-extract-eob
lambda:InvokeFunction	eob-validate-data
lambda:InvokeFunction	eob-lookup-insurance
lambda:InvokeFunction	eob-store-result
logs:CreateLogDelivery, logs:GetLogDelivery, logs:UpdateLogDelivery, logs>DeleteLogDelivery, logs:ListLogDeliveries, logs:PutResourcePolicy, logs:DescribeResourcePolicies, logs:DescribeLogGroups	/aws/stepfunctions/eob-extractor log group
xray:PutTraceSegments, xray:GetSamplingRules, xray:GetSamplingTargets	* (X-Ray tracing)

3. KMS Key Policies

alias/eob-extractor/phi

Description: Encrypts PHI data in DynamoDB and Lambda environment variables.

Principals with key usage: - Lambda execution roles: `eob-trigger` (Decrypt), `eob-validate-pdf` (Decrypt), `eob-classify-eob` (Decrypt), `eob-extract-eob` (Decrypt), `eob-store-result` (Encrypt, Decrypt, GenerateDataKey) - DynamoDB service (transparent — granted via table-level encryption) - SQS service (queues encrypted with this key)

Key rotation: Enabled (annual automatic rotation)

alias/eob-extractor/audit

Description: Encrypts audit logs in CloudWatch and S3.

Principals with key usage: - CloudWatch Logs service (`logs.{region}.amazonaws.com`) — condition: `aws:logs:arn` matches `arn:aws:logs:{region}:{account}:log-group:*` - Step Functions execution role (log group write) - S3 service (audit bucket encryption)

Key rotation: Enabled (annual automatic rotation)

4. S3 Bucket Permissions

bucket-specialops / bucket-specialops-sandbox (imported)

CDK uses `Bucket.fromBucketName()` — the bucket is not managed by this stack. Permissions are granted per-Lambda via `grantRead()` / `grantPut()` which add bucket policy statements.

Lambda	Prefix	Actions
eob-validate-pdf	clickup/*	s3:GetObject
eob-validate-pdf	quarantine/*	s3:PutObject
eob-classify-eob	clickup/*	s3:GetObject
eob-extract-eob	clickup/*	s3:GetObject

Note (Audit #009): The bucket itself is not IaC-managed. Verify that `Block Public Access` is enabled, versioning is on, and SSE-KMS is configured outside of this stack.

eob-extractor-audit-{account} (CDK-managed)

Setting	Value
Block public access	ALL blocked
Versioning	Enabled
Encryption	KMS — <code>alias/eob-extractor/audit</code>
Object Lock mode	COMPLIANCE
Object Lock retention	2190 days (6 years)
SSL enforcement	<code>aws:SecureTransport</code> required
Lifecycle	IA after 90 days; Glacier after 365 days

5. SQS Queue Encryption

All queues are encrypted with KMS (`QueueEncryption.KMS`):

Queue	KMS Key
eob-extractor-ingest	<code>alias/eob-extractor/phi</code>
eob-extractor-review	<code>alias/eob-extractor/phi</code>
eob-extractor-dlq	<code>alias/eob-extractor/phi</code>

6. Permission Boundary

The CDK stack includes a `PermissionBoundaryAspect` (`lib/aspects/permission-boundary.aspect.ts`). If a permission boundary ARN is configured, it is applied to all IAM roles created by the stack to enforce an upper bound on permissions regardless of attached policies.

7. IAM Audit Checklist

- [] No wildcard `*` on data resources (S3, DynamoDB, SQS) — all constrained to specific ARNs
- [] Bedrock `InvokeModel` scoped to specific foundation model and inference profile ARNs per region
- [] KMS grants use the minimum action set per Lambda (Decrypt only where Encrypt is not needed)
- [] `Insurance-Arbitration-contacts` write access limited to `eob-lookup-insurance` only
- [] No Lambda has cross-account permissions
- [] CloudWatch Logs KMS grant scoped to `kms:EncryptionContext:aws:logs:arn` condition